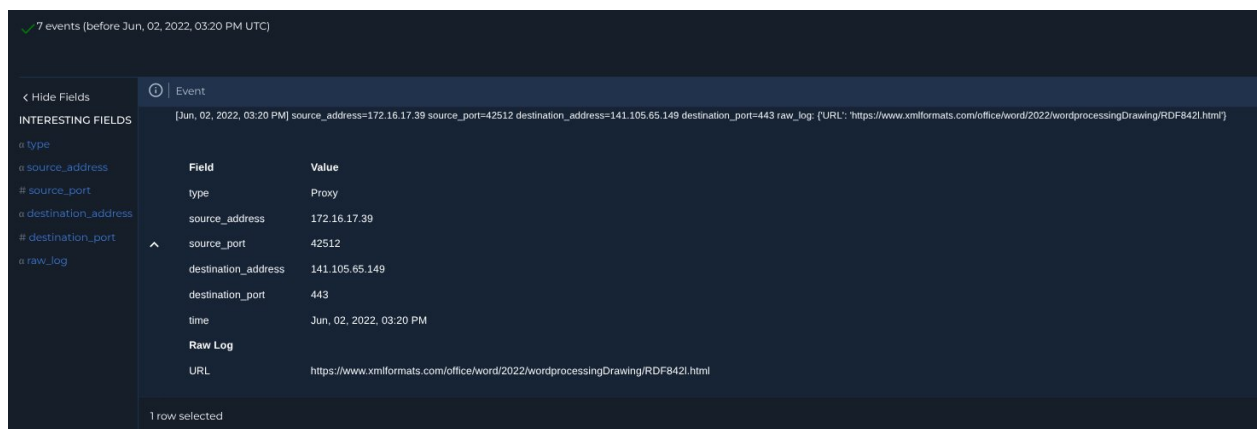


Event Information:

EventID :
123
Event Time :
Jun, 02, 2022, 03:22 PM
Rule :
SOC173 - Follina 0-Day Detected
Level :
Security Analyst
Source Address :
172.16.17.39
Hostname :
JonasPRD
File Name :
05-2022-0438.doc
File Hash :
52945af1def85b171870b31fa4782e52
File Size :
10.01 Kb
AV Action :
Allowed
Alert Trigger Reason :
msdt.exe executed after Office document

Analysis Steps:

Logs were searched with victim IP 172[.]16.17.39 hostname JonasPRD in the relevant time-frame yielding 7 events where suspicious requests can be seen to a domain attempting to pose as an official Microsoft domain.

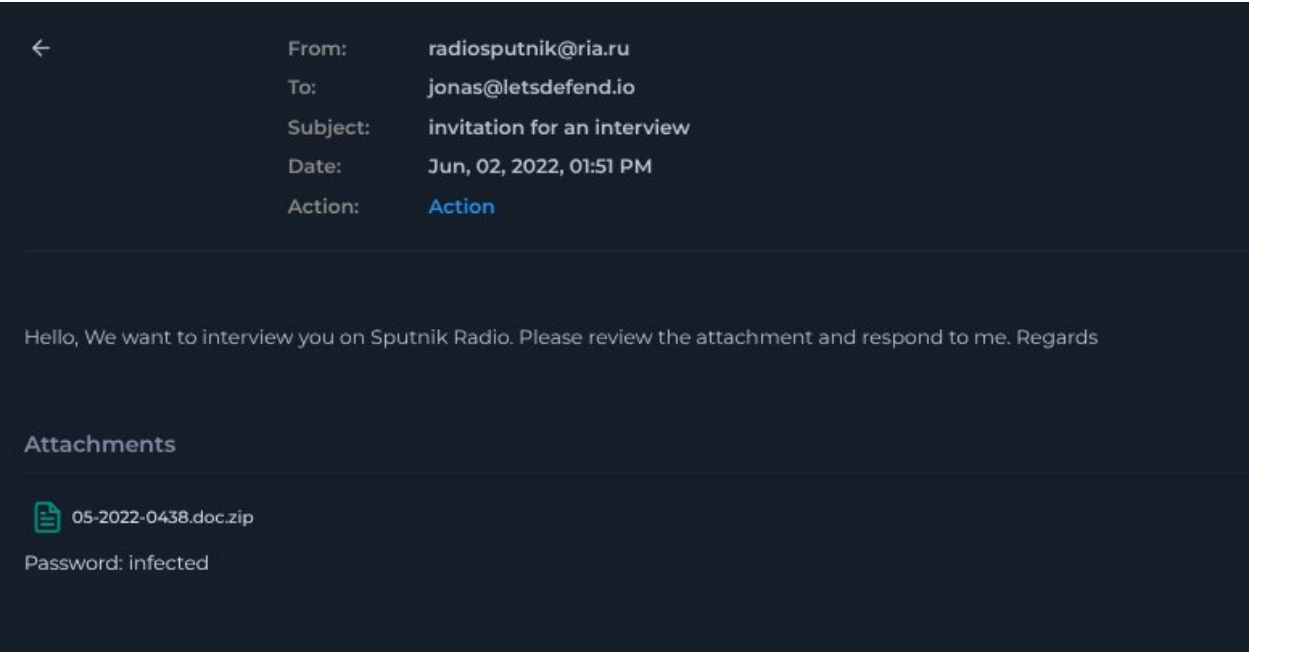


The proxy logs show the endpoint fetching a specific file:
`hxxps://www.xmlformats[.]com/.../RDF842l.html`

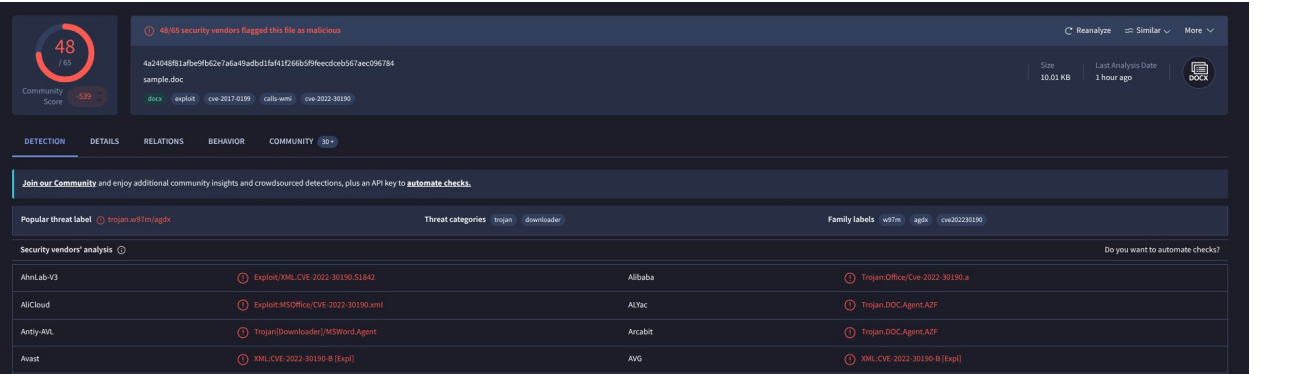
This is the core mechanic of the Follina (CVE-2022-30190) vulnerability. Instead of hiding the malicious code inside a macro within the Word document itself, the attacker abuses Word's remote template feature. When the user views the document, Word reaches out to the attacker's server and pulls down that malicious HTML file.

The initial alert of msdt.exe executed after Office document can act as evidence of the Follina exploit succeeding in execution.

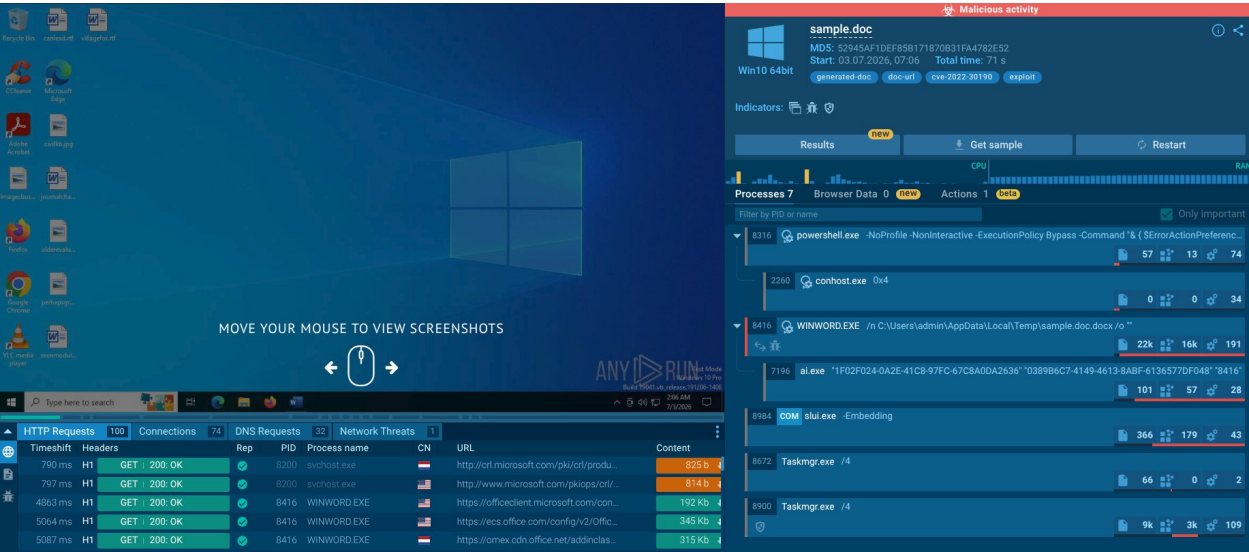
It would appear that the malicious file was initially delivered to the endpoint via a phishing email seen in the image below.



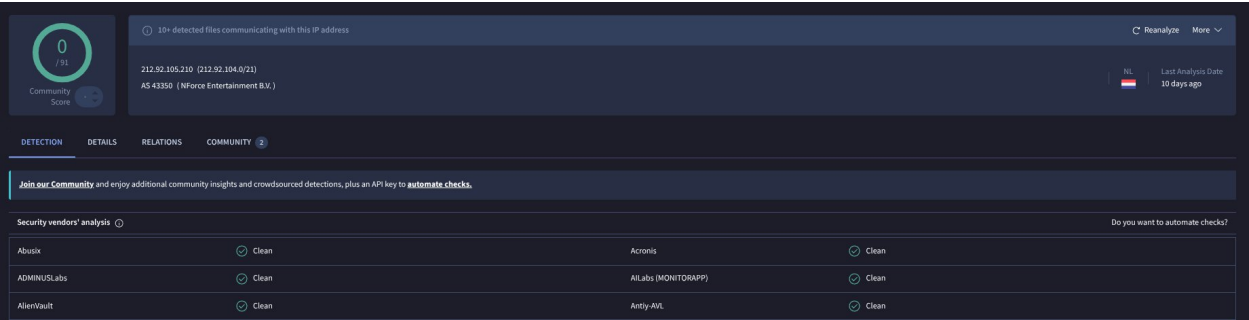
On VirusTotal the files is marked as a malicious Trojan by 48/65 Vendors as of one hour ago.



A report for the malicious file can also be found on AnyRun indicating malicious behaviour.



The offending IP related to the malicious domain is not in our CTI database and is external to the organisation. No emails have been received indicating penetration testing involving the IP for the relevant time period. VirusTotal indicates it is a Dutch address associated with 212[.]92.105.210 AS 43350 (NForce Entertainment B.V.). 0/91 mark the IP as malicious as of 10 days ago.



On AbuseIPDB this IP was reported 0 times with a 0% confidence of abuse.

212.92.105.210 was not found in our database

This IP was reported 0 times. Confidence of Abuse is 0%: ?

0%

ISP	NForce Entertainment B.V.
Usage Type	Data Center/Web Hosting/Transit
ASN	AS43350
Domain Name	nforce.com
Country	 Netherlands
City	Roosendaal, North Brabant

Based on following Playbook procedure and the analysis of available information, this alert is determined to be a successful True Positive.

Report:

Incident Summary

Analysis confirms a True Positive Follina (CVE-2022-30190) vulnerability exploit on the host JonasPRD (172[.]16.17.39). An external threat actor successfully delivered a malicious Word document via a phishing email. Upon interaction, the document abused the Word remote template feature to download a malicious HTML payload from a spoofed external domain, subsequently executing msdt.exe on the endpoint.

Incident Details

- **Alert Name:** SOC173 - Follina 0-Day Detected
- **Target Host:** JonasPRD (172[.]16.17.39)
- **Malicious File:** 05-2022-0438.doc
- **Attack Vector:** Phishing email with ZIP attachment

Analysis and Evidence

- **Initial Access:** Email logs confirm the delivery of a spearphishing email originating from radiosputnik[.]ria[.]ru containing the malicious payload disguised as an interview invitation.
- **Attack Execution:** Proxy logs confirm the document successfully reached out to a spoofed Microsoft formatting domain (hxxps://www.xmlformats[.]com/.../RDF842l.html) to fetch a malicious HTML template.
- **Success Confirmation:** The endpoint successfully executed the Microsoft Support Diagnostic Tool (msdt.exe) immediately following the Office document interaction, which is the definitive indicator of compromise for a successful Follina exploit. Sandbox analysis (AnyRun) further corroborates the malicious behaviour of the document.

Threat Intelligence

- **OSINT:** VirusTotal analysis of the document hash confirms it is a malicious exploit (48/65 vendors). The external IP associated with the malicious domain (212[.]92.105.210) is external to the organisation.
- **Internal Correlation:** A review of internal communications confirmed no authorised Red Team testing or phishing simulations were scheduled.

Actions Taken

1. Contained host JonasPRD (172[.]16.17.39) to prevent lateral movement and further payload execution.
2. Deleted the malicious email from the user's inbox to prevent secondary interaction.
3. Declared the alert a True Positive.
4. Escalated the alert further analysis.

Let's Defend Result

SOC173 - Follina 0-Day Detected

True Positive (+5 Point)

Check If Someone Requested the C2 (+5 Point)

Analyze Malware (+5 Point)

Check if the malware is quarantined/cleaned (+5 Point)